

Penetration Testing Project

Mediroza General Hospital

Batch B083 | Week 4

Target: <https://medirozahospital.com>

**CLIENT**

Mediroza General Hospital

TYPE

Black-box Pentest

DURATION

5 Days

This project is conducted in a controlled environment for educational purposes only. These techniques must never be applied to any system without explicit written permission from the owner.

PENETRATION TESTING REPORT

Black-Box Security Assessment

Project: Mediroza General Hospital Penetration Testing

Program: Cybersecurity Internship – Networkwalks

Module: Week 4

Assessment Type: Black-Box Penetration Testing

Target: Mediroza General Hospital

Target URL: <https://medirozahospital.com>

Duration: 5 Days

Status: Final – All Milestones Completed

Performed by: Rohith K R - [linkedin.com/in/rohith-k-r-55236a30b](https://www.linkedin.com/in/rohith-k-r-55236a30b)

1. Executive Summary

This report presents the results of an authorized black-box penetration testing assessment conducted against the **Mediroza General Hospital** web application. The assessment was performed in a controlled environment with permission from the client and was conducted for educational and security-testing purposes.

The assessment covered multiple stages of penetration testing, including reconnaissance, network and application scanning, initial access testing, data extraction, password recovery, and sensitive information discovery.

During **Milestone 1 (Initial Access)**, reconnaissance activities were performed using multiple Kali Linux tools to identify publicly available information about the target. Network scanning was then conducted to identify exposed services. Further analysis of the patient portal identified a SQL Injection vulnerability in the authentication functionality, which allowed authentication to be bypassed within the authorized testing environment.

During **Milestone 2 (Data Extraction)**, password-protected PDF documents were analyzed. Password hashes were extracted using pdf2john and tested offline using John the Ripper. One weak PDF password was successfully recovered.

During **Milestone 3**, reconnaissance of robots.txt revealed several directories, including /old/. Investigation of this directory identified an exposed legacy database-related resource named sql-db-2019.

The assessment identified security issues involving **SQL Injection, exposed legacy resources, weak document passwords, and information disclosure through robots.txt**. These findings demonstrate the importance of secure input handling, proper access controls, strong password policies, and regular security assessments.

2. Scope and Methodology

2.1 Scope

The assessment focused on the authorized web application and associated resources belonging to the Mediroza General Hospital testing environment.

Project Information

Parameter	Details
Client / Target:	Mediroza General Hospital
Target URL:	https://medirozahospital.com
Testing Type:	Black-Box Penetration Testing
Permission:	Authorized
Duration:	5 Days

Parameter	Details
-----------	---------

Program / Batch	B083 – Week 4
-----------------	---------------

Mentor:	Waqas Karim, CCIE
---------	-------------------

Status:	Final – All Milestones Completed
---------	----------------------------------

2.2 Methodology

The penetration testing assessment followed a structured approach consisting of reconnaissance, scanning, vulnerability identification, controlled exploitation, data extraction, and security analysis.

Milestones Completed

Milestone	Activity	Description
M1 – Initial Access	Website Testing	Performed reconnaissance and security testing of the authorized target website and identified a SQL Injection vulnerability in the login functionality.
M2 – Data Extraction	File Password Recovery	Extracted password hashes from protected PDF files and performed offline password recovery testing.
M3 – Attack / Cracking	Sensitive Data Discovery	Investigated exposed resources and identified a legacy database-related file and sensitive information within the authorized environment.

2.3 Tools Used

Tool	Purpose
Kali Linux	Operating system used for reconnaissance and penetration testing activities.
WHOIS	Used to collect domain registration and nameserver information.
WhatWeb	Used to identify technologies and server-related information used by the target website.
nslookup	Used to resolve the domain name and identify its associated IP address.
curl -I	Used to inspect HTTP response headers returned by the web server.

Tool	Purpose
WAFW00F	Used to identify whether a Web Application Firewall may be protecting the target.
Zenmap	Used to identify open ports and potentially exposed network services.
SQL Injection	Used in the authorized environment to test the login functionality for input-handling vulnerabilities and authentication bypass.
Hash Extractor	Used to extract password hashes from password-protected PDF files.
pdf2john	Used to convert PDF password information into a format suitable for John the Ripper.
John the Ripper	Used for offline password recovery testing against extracted PDF password hashes.

The tool selection and their stated purposes are based on the project README.

3. Findings and Proof of Exploitation

3.1 M1 – Initial Access

The first stage of the assessment focused on reconnaissance and identification of the target's publicly available information.

Several Kali Linux reconnaissance tools were used, including **WHOIS**, **WhatWeb**, **nslookup**, **curl**, and **WAFW00F**. These activities provided information relating to the target domain, server, IP address, publicly visible technologies, HTTP response information, and possible Web Application Firewall protection.

Network scanning was subsequently performed using **Zenmap** to identify exposed services. Ports **80** and **443** were identified as open.

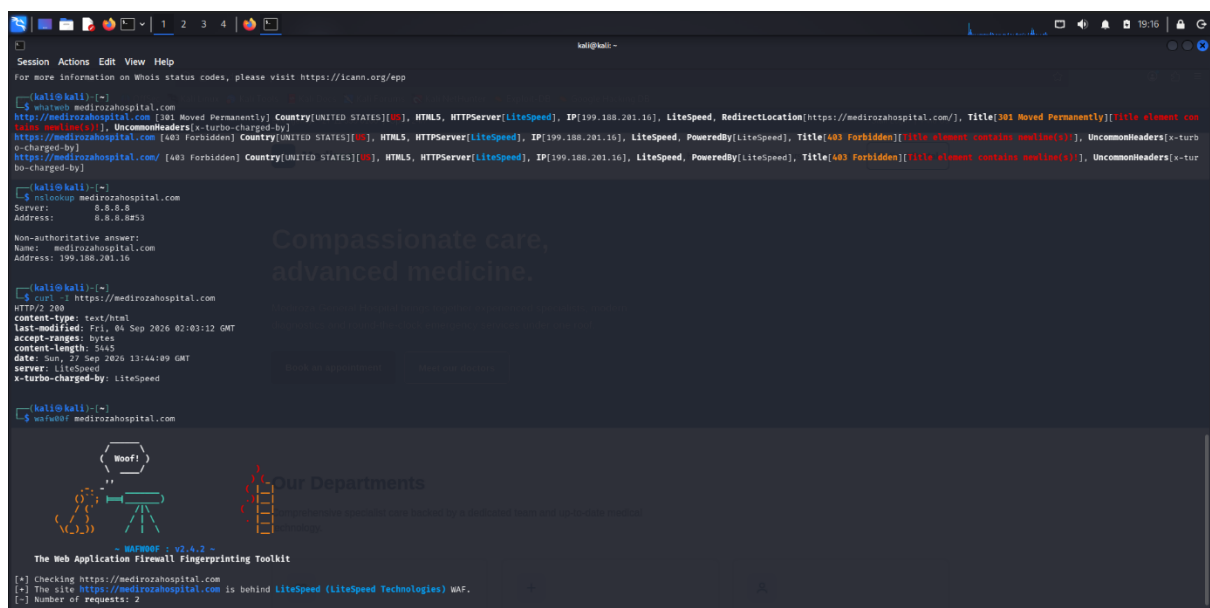
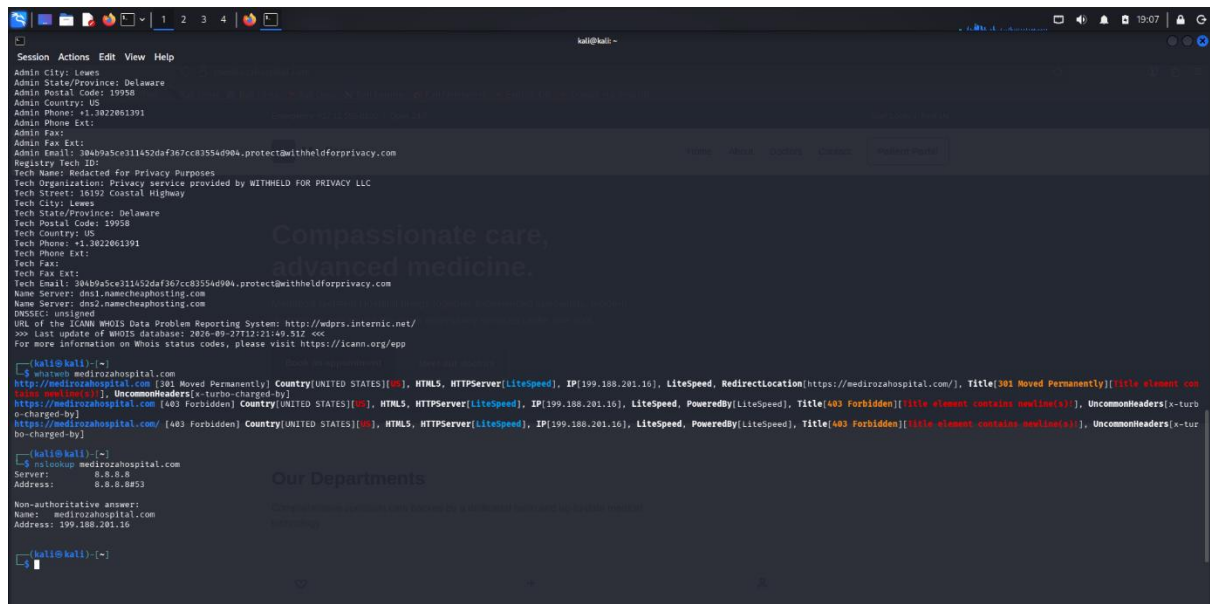
Further analysis of the patient portal was conducted to understand its authentication functionality and application behavior. During testing, the login functionality was found to be vulnerable to **SQL Injection** because user-supplied input was improperly incorporated into the backend SQL query.

Within the authorized testing environment, a crafted input was able to alter the authentication query and bypass normal password verification. This resulted in successful authentication without providing the legitimate account password.

Security Impact

A SQL Injection vulnerability in an authentication mechanism can allow an attacker to bypass authentication and potentially access protected application functionality or sensitive account information.

Evidence



```
Session Actions Edit View Help
2026-09-30T12:23:38.215703-0400 INFO SRV _autodiscover._tcp.medirozahospital.com cpanel.net 104.94.204.14 443
2026-09-30T12:23:38.215892-0400 INFO SRV _autodiscover._tcp.medirozahospital.com cpanel.net 104.94.204.9 443
2026-09-30T12:23:38.216045-0400 INFO SRV _autodiscover._tcp.medirozahospital.com cpanel.net 104.94.204.15 443
2026-09-30T12:23:38.216311-0400 INFO SRV _autodiscover._tcp.medirozahospital.com cpanel.net 104.94.204.11 443
2026-09-30T12:23:38.230619-0400 INFO 12 Records Found
2026-09-30T12:23:38.231099-0400 INFO Completed enumeration for domain: medirozahospital.com

(hali@kali)-[~]
└─$ curl -i https://medirozahospital.com
HTTP/2 200
server: openresty/1.21.1.1
date: Wed, 30 Sep 2026 16:25:13 GMT
content-length: 12167
content-type: text/html
cache-control: private, no-cache, no-store, must-revalidate, max-age=0
cf-edge-cache: no-cache

<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<meta name="viewport" content="width=device-width,initial-scale=1.0">
<script>
(function(){
(function(){
setTimeout(function(){
window.location.reload();
}, 5000);
})();
})();
</script>
<link rel="icon" href="data:,">
<title>One moment, please...</title>
<style>
.spinner {
-webkit-animation: spin 1s ease-out;
animation: spin 1s ease-out;
}
@keyframes spin {
0% {
-webkit-transform: rotate(0deg);
-ms-transform: rotate(0deg);
-moz-transform: rotate(0deg);
-o-transform: rotate(0deg);
transform: rotate(0deg);
}
100% {
-webkit-transform: rotate(360deg);
-ms-transform: rotate(360deg);
-moz-transform: rotate(360deg);
-o-transform: rotate(360deg);
transform: rotate(360deg);
}
}

```

```
Scan Tools Profile Help
Target: medirozahospital.com
Command: nmap-T4-A-v.medirozahospital.com
Profile: Intense scan
Scan Cancel

Hosts Services
Nmap Output Ports/Hosts Topology Host Details Scans
OS Host
medirozahospital
nmap-T4-A-v.medirozahospital.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-30 12:32 -0400
NSE Loaded 158 scripts for scanning.
NSE Script Pre-scanning.
Initiating NSE at 12:32
Completed NSE at 12:32, 0.00s elapsed
Initiating NSE at 12:32
Completed NSE at 12:32, 0.00s elapsed
Initiating NSE at 12:32
Completed NSE at 12:32, 0.00s elapsed
Initiating Parallel DNS resolution of 1 host. at 12:32
Completed Parallel DNS resolution of 1 host. at 12:32, 1.05s elapsed
Initiating Ping Scan at 12:32
Scanning medirozahospital.com [199.188.201.16] [4 ports]
Completed Ping scan at 12:32, 0.01s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 12:32
Completed Parallel DNS resolution of 1 host. at 12:32, 0.17s elapsed
Initiating SYN Stealth Scan at 12:32
Scanning medirozahospital.com [199.188.201.16] [1000 ports]
Discovered open port 443/tcp on 199.188.201.16
Discovered open port 80/tcp on 199.188.201.16
Discovered open port 80/tcp on 199.188.201.16
Discovered open port 443/tcp on 199.188.201.16
Completed SYN Stealth Scan at 12:32, 18.00s elapsed (1000 total ports)
Initiating Service scan at 12:32
Scanning 2 services on medirozahospital.com [199.188.201.16]
Completed Service scan at 12:32, 13.01s elapsed (2 services on 1 host)
Initiating OS detection (try #1) against medirozahospital.com [199.188.201.16]
Retrying OS detection (try #2) against medirozahospital.com [199.188.201.16]
Initiating Traceroute at 12:32
Completed Traceroute at 12:32, 0.81s elapsed
NSE Script scanning 199.188.201.16
Initiating NSE at 12:32
Completed NSE at 12:33, 14.22s elapsed
Initiating NSE at 12:33
Completed NSE at 12:33, 3.15s elapsed
Initiating NSE at 12:33
Completed NSE at 12:33, 0.00s elapsed
Nmap scan report for medirozahospital.com [199.188.201.16]
Filter Hosts
Host is up (0.030s latency).
```

3.2 M2 – Data Extraction

Following the initial access stage, password-protected PDF documents were identified within the authorized testing environment.

The password-protection information was extracted using **pdf2john**, which prepared the relevant information for offline password recovery using **John the Ripper**.

The extracted password hash was then analyzed using John the Ripper. One of the tested PDF passwords was successfully recovered as:

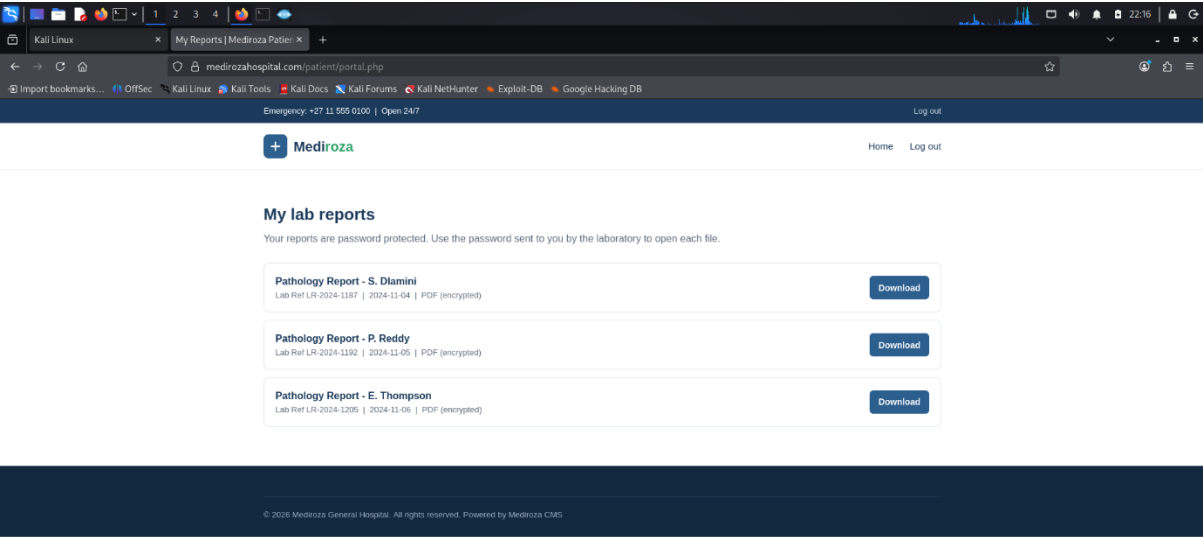
password

The recovered password was subsequently used to verify access to the protected document.

Security Impact

The successful recovery of a weak document password demonstrates that commonly used passwords can provide inadequate protection for sensitive documents. If such documents contain confidential information, weak password protection could result in unauthorized disclosure.

Evidence



PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:	Sipho Dlamini	Report Date:	2024-11-04
Patient ID:	MG-P-10231	Referring Dr:	Dr. Anita Naicker
Date of Birth:	1984-06-12	Specimen:	Whole blood (EDTA)
Gender:	Male	Lab Ref No:	LR-2024-1187

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	$\times 10^9/L$	4.0 - 11.0	HIGH
Platelet Count	245	$\times 10^9/L$	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:	Priya Reddy	Report Date:	2024-11-05
Patient ID:	MG-P-10244	Referring Dr:	Dr. Johan van der Merwe
Date of Birth:	1991-02-28	Specimen:	Serum
Gender:	Female	Lab Ref No:	LR-2024-1192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Susan Botha, MBBCh FCPATH

Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)

This report is confidential and intended only for the named patient and the referring clinician.

Verified electronically. No signature required. Mediroza CMS 1.4.2

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Emily Thompson

Report Date:

2024-11-06

Patient ID:

MG-P-10258

Referring Dr:

Dr. Ahmed Kara

Date of Birth:

1978-09-03

Specimen:

Serum

Gender:

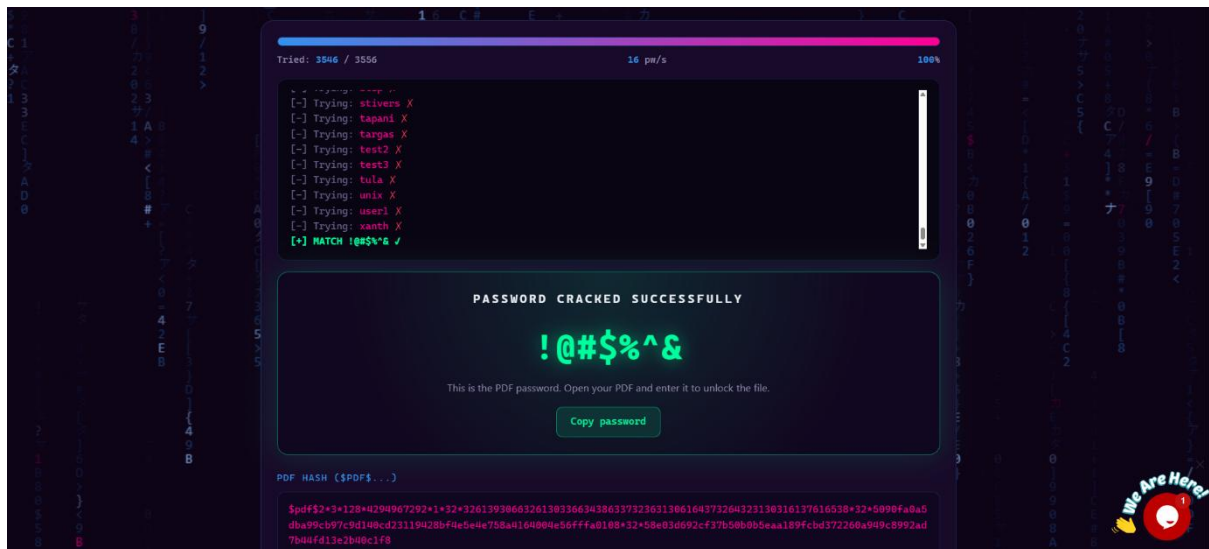
Female

Lab Ref No:

LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Reported by: Dr. Rajesh Naidoo, MBBCh FCPath
Mediroza Diagnostics Lab - SANAS accredited pathology laboratory (Ref M0417)
This report is confidential and intended only for the named patient and the referring clinician.
Verified electronically. No signature required. Mediroza CMS 1.4.2



3.3 M3 – Sensitive Data Discovery

During the reconnaissance and investigation phase, the target's robots.txt file was inspected.

The file disclosed several application paths, including:

- /patient/
- /staff/
- /old/

The /old/ directory was investigated because it indicated the presence of older or potentially deprecated website resources.

During the investigation, a database-related file named **sql-db-2019** was identified within the exposed directory.

The discovery can be summarized as:

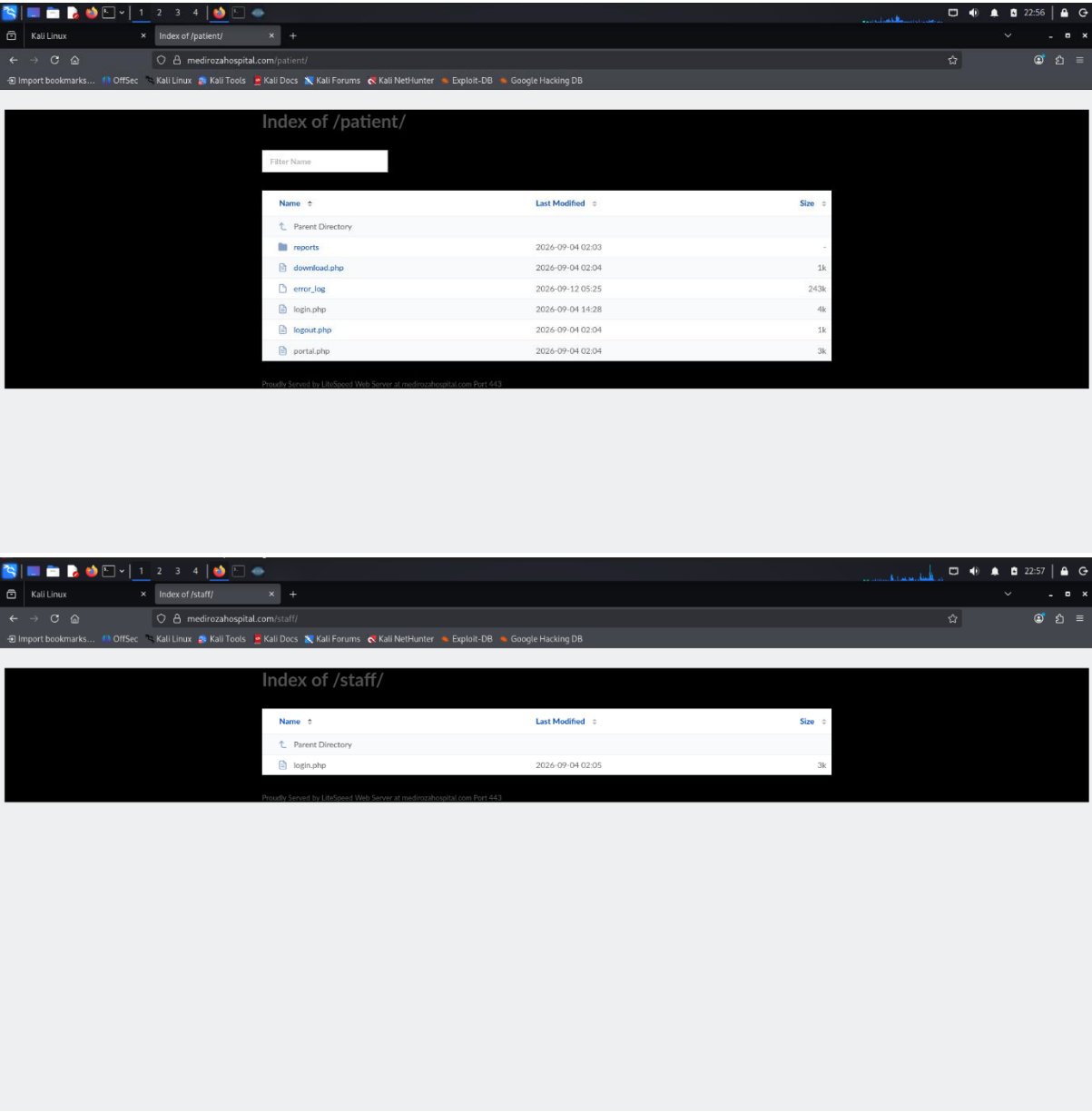
robots.txt → /old/ directory → sql-db-2019

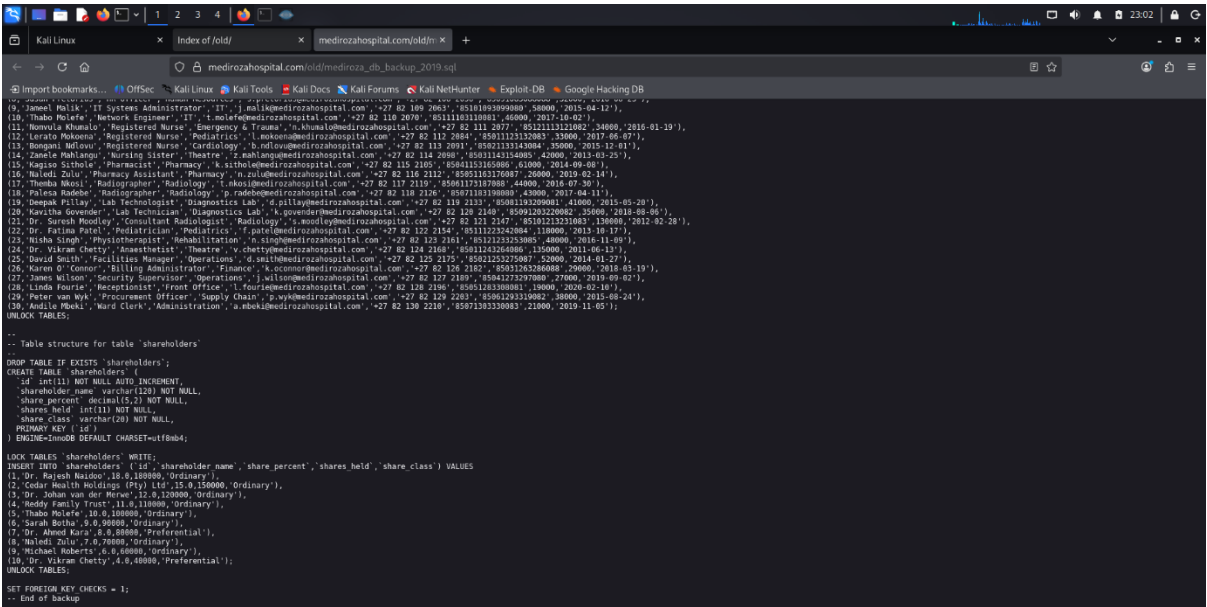
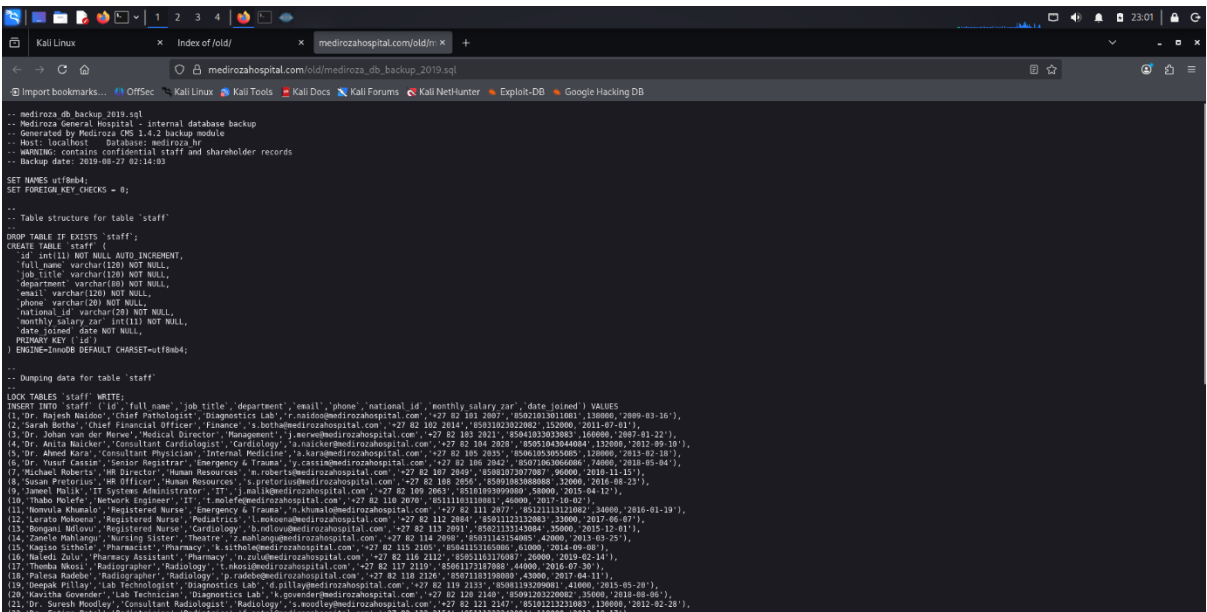
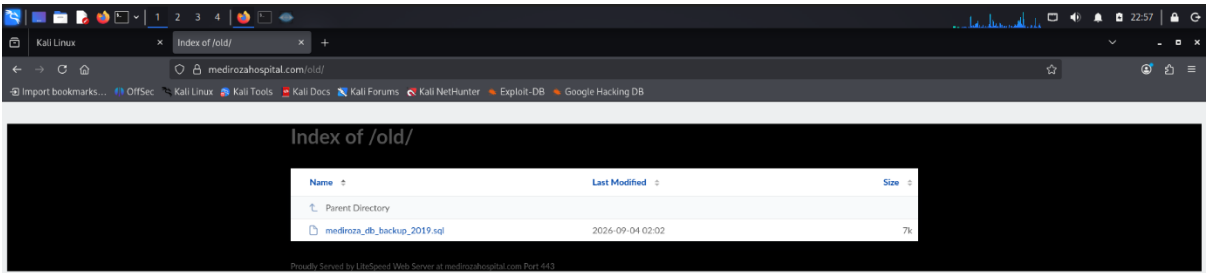
The presence of an old database-related resource within a publicly accessible location represents an information-disclosure concern and may provide useful information about the application's underlying data or infrastructure.

Security Impact

Exposed legacy resources can increase the risk of sensitive information disclosure and may provide additional information that could assist further security testing or attacks.

Evidence





Recommendation

Unnecessary legacy files and directories should be removed from the publicly accessible web root. Sensitive database-related resources should be stored outside publicly accessible locations and protected through appropriate access controls.

The README specifically documents this discovery and its security impact.

4. Risk Rating

The identified vulnerabilities were categorized according to their potential security impact and the evidence obtained during the assessment.

Finding	Evidence / Observation	Potential Impact	Risk Level
SQL Injection – Authentication Bypass	The login functionality accepted crafted input that altered the authentication query and bypassed password verification in the authorized environment.	Could allow authentication bypass and unauthorized access to protected application functionality or account information.	High
Exposed Legacy Database Resource	The /old/ directory identified through robots.txt contained a database-related resource named sql-db-2019.	May disclose sensitive information about application data or internal infrastructure and assist further attacks.	Medium
Weak PDF Password	A password-protected PDF was successfully accessed after its password hash was analyzed using John the Ripper.	Weak passwords may allow unauthorized access to protected documents and sensitive information.	Medium
Information Disclosure Through robots.txt	robots.txt disclosed paths including /patient/, /staff/, and /old/.	Can assist application mapping and reveal potentially sensitive locations for further investigation.	Low

These risk levels and their associated observations are taken directly from the supplied project material.

5. Recommendations and Remediation

Based on the findings identified during the penetration testing assessment, the following remediation measures are recommended.

5.1 SQL Injection – Authentication Bypass

The application should implement secure database interaction mechanisms to prevent user input from being interpreted as part of SQL queries.

Recommended actions:

- Use **prepared statements and parameterized queries** instead of directly concatenating user input into SQL queries.
 - Implement strict server-side input validation.
 - Prevent database error messages from being exposed to end users.
 - Implement secure authentication mechanisms.
 - Ensure that both username and password information are properly validated before authentication is granted.
 - Conduct regular security testing of authentication and input fields.
-

5.2 Exposed Legacy Database Resource

Legacy files and directories should not remain publicly accessible on production web servers.

Recommended actions:

- Remove unnecessary legacy directories such as /old/.
- Store database backups and database-related resources outside the publicly accessible web root.
- Perform regular reviews of the web server for forgotten, outdated, or unnecessary files.
- Implement appropriate authentication and authorization controls for sensitive resources.

5.3 Weak PDF Password

Strong password policies should be applied to documents containing sensitive information.

Recommended actions:

- Replace weak passwords with strong and unique passwords.
- Use a combination of uppercase and lowercase characters, numbers, and special characters.
- Avoid commonly used passwords such as password.
- Where appropriate, use stronger encryption and access-control mechanisms for sensitive PDF documents.
- Review existing protected documents and replace weak or compromised passwords.

5.4 Information Disclosure Through robots.txt

The robots.txt file should not be treated as a security mechanism because it does not prevent users from accessing the listed paths.

Recommended actions:

- Avoid using robots.txt to protect sensitive resources.
- Remove unnecessary or sensitive directories from the publicly accessible web server.
- Implement proper authentication and authorization controls.
- Review robots.txt regularly to ensure that it does not unnecessarily disclose sensitive application structure.

5.5 General Security Improvements

In addition to addressing the individual findings, the following general security improvements are recommended:

- Keep web applications, servers, frameworks, and libraries updated.
- Implement centralized logging and monitoring for suspicious authentication and web requests.

- Conduct periodic vulnerability assessments and penetration tests.
- Apply the principle of least privilege to application and database accounts.
- Prevent unnecessary exposure of sensitive information through error messages, directories, backups, and legacy files.
- Establish a regular process for identifying and removing outdated resources.

The remediation recommendations above are aligned with the supplied README's recommendations.

Conclusion

The black-box penetration testing assessment of the Mediroza General Hospital environment identified several security weaknesses across authentication, document protection, information disclosure, and legacy resource management.

The most significant finding was the **SQL Injection vulnerability affecting the authentication functionality**, which demonstrated the potential for authentication bypass within the authorized testing environment. Additional findings included a weak PDF password, exposure of a legacy database-related resource, and information disclosure through robots.txt.

Addressing these vulnerabilities through secure coding practices, stronger access controls, improved password policies, removal of unnecessary legacy resources, and continuous security testing can help reduce the overall attack surface and improve the security of the application.

Liability Disclaimer

All testing activities described in this report were performed only against systems for which authorization had been obtained or within a controlled educational environment. The techniques and information presented in this report are intended strictly for **educational, research, and authorized security-testing purposes**.
